

Cyber Tabletop Exercise

Data Integrity Attack on AML and Sanctions Screening

Scenario source: STIX bundle provided by the user.

Scenario title: TTX Scenario 10 - Data integrity attack on AML and sanctions screening.

Sector: Financial services.

Primary audience: Executive, operational, technical, compliance, legal, and crisis-management stakeholders.

1. Introduction

This tabletop exercise simulates a cyber-related integrity failure affecting the bank's AML and sanctions screening platform. The scenario is designed to test the organization's ability to recognize an integrity issue in a critical compliance control, assess immediate regulatory and operational impact, activate the appropriate crisis and incident response structures, and decide how to contain, remediate, and retrospectively review affected transactions.

The exercise is based on a STIX scenario in which screening logic fails open, allowing transactions to proceed without proper sanctions and AML checks. The exercise is intended to drive discussion on control assurance, compensating measures, payment operations, legal and compliance escalation, and regulatory communications.

2. Exercise Objectives

The objectives for this exercise are to develop decision-making reflexes and improve coordination among business, compliance, technology, and crisis-management teams. The exercise will test the organization's ability to:

- Detect and validate abnormal behavior in AML and sanctions screening outcomes.
- Assess whether the issue is a cyber incident, a data integrity event, an operational failure, or a combination of the three.
- Determine whether payment classes or customer segments should be paused, queued, or subject to compensating controls.
- Reconstruct the affected transaction population and define a retrospective screening approach.
- Escalate appropriately to compliance leadership, executive management, legal, and relevant regulators.
- Coordinate internal and external communications while preserving evidence and maintaining decision logs.
- Define recovery criteria before resuming normal processing.
- Capture lessons learned for integrity monitoring, fail-open prevention, and compliance contingency planning.

3. Scope

In scope

- AML and sanctions screening platform
- Payment operations and transaction flows
- Compliance operations and financial crime teams
- Security operations and incident response
- IT application support and infrastructure teams
- Legal, privacy, internal audit, communications, and crisis management
- Regulatory notification and follow-up decision making

Out of scope

- Detailed forensic malware analysis
- Vendor contract negotiation
- Full legal opinion on notification thresholds by jurisdiction
- Technical restoration steps at implementation level

4. Intended Participants

Executive audience

- Country or business leadership
- Crisis management lead
- Chief compliance / MLRO equivalent
- Chief information security leadership
- General counsel / legal leadership

Operational audience

- Compliance operations
- Payment operations / transaction services
- Fraud and financial crime teams
- Business continuity leads
- Communications and stakeholder management leads

Technical audience

- SOC / cyber incident response
 - Application support owners
 - Infrastructure and database teams
 - Logging, monitoring, and data integrity teams
 - IAM / privileged access teams
-

5. Exercise Structure

- Recommended duration: 60 to 90 minutes
 - Format: Facilitated discussion-based tabletop exercise
 - Delivery model: Sequential injects followed by debrief questions
 - Assumption: Participants respond according to existing roles, responsibilities, and procedures
 - Timeline convention: Relative timeline beginning at the point of discovery
-

6. Rules of Engagement

- Real-world incidents take priority.
 - There are no right or wrong answers; the purpose is to surface strengths, gaps, and decisions.
 - Participants should respond as if the incident were real.
 - The scenario is designed to test processes and coordination, not to criticize a specific team or system owner.
 - Participants should avoid debating away the scenario and instead focus on realistic decisions and actions.
 - Assumptions made during the exercise should be stated clearly.
-

7. Scenario Background

The bank relies on an AML and sanctions screening platform to apply watchlists, interdiction rules, and screening logic to customer and transaction activity. The platform is a key compliance control within payment and transaction processing.

Unknown to the organization at the start of the exercise, the integrity of the screening process has been compromised. Screening logic has failed open, meaning transactions are continuing to flow but some or all are no longer receiving the expected sanctions and AML screening. The event may stem from malicious tampering, unauthorized change, data corruption, or a control failure triggered by error conditions.

The incident creates immediate uncertainty across several dimensions:

- Whether prohibited or suspicious transactions have already been processed
 - Whether the issue is still ongoing
 - Which transaction classes are affected
 - Whether compensating controls are sufficient
 - Whether regulators must be notified immediately
 - How quickly the bank can reconstruct and re-screen the impacted population
-

8. Asset Overview

AML and sanctions screening platform

The platform applies sanctions lists, rules, interdiction logic, and transaction/customer screening controls. It supports:

- Sanctions and watchlist screening
- AML alert generation
- Exception handling and review workflows
- Decisioning that determines whether transactions proceed, queue, or are blocked
- Auditability of rule changes, watchlist updates, and screening outcomes

Business criticality

Failure of this platform can create:

- Regulatory exposure
 - Potential sanctions breaches
 - AML control failure
 - Reputational damage
 - Transaction backlogs and customer impact
 - Heightened board and regulator scrutiny
-

9. Scenario Narrative

During a normal business period with expected transaction throughput, compliance operations notices that sanctions and AML alert volumes have unexpectedly dropped to zero. At first glance, this appears inconsistent with usual patterns and raises concern that the screening platform may not be functioning correctly.

As the incident develops, the organization must determine whether screening controls are failing silently, whether transactions should continue to be processed, what compensating controls can be applied, and when senior management and regulators should be informed. Later, the organization faces pressure to reconstruct the affected transaction population, decide on retrospective screening, and determine how to safely restore confidence in the control environment.

10. Master Timeline and Injects

Inject 1 — Abnormal alert volume collapse

Time: T+0

Inject statement

Compliance operations notices that sanctions and AML alert volumes have dropped abnormally during a period of normal transaction throughput.

What participants know at this stage

- Transaction volumes appear normal.
- AML and sanctions alerts have fallen to zero or near zero unexpectedly.
- No approved maintenance window is known.
- It is not yet confirmed whether this is a monitoring issue, a rule issue, a data integrity issue, or an active cyber incident.

Facilitator prompts

- Who validates whether the drop in alerts reflects a real control failure versus a dashboard or telemetry issue?
- What immediate checks should be performed on rule integrity, watchlist updates, system logs, and recent changes?
- At what threshold should this be classified as a compliance incident, cyber incident, or crisis event?
- What transaction classes, geographies, or customer segments should be prioritized for review?
- What is the immediate communication path among compliance, operations, IT, security, and management?

Expected actions

- Validate whether screening execution is occurring end-to-end.
- Review recent changes to rules, watchlists, configurations, data feeds, and access activity.
- Open an incident and assign an initial severity based on potential control failure impact.
- Preserve logs and change history.
- Consider immediate compensating controls for high-risk transactions.
- Start decision logging and establish incident governance.

Facilitator notes

- Push participants to distinguish availability from integrity. The system may appear online while the control outcome is invalid.
- Look for discussion of fail-open versus fail-closed design and whether business teams understand the difference.

Inject 2 — Transaction lookback and regulator pressure

Time: T+2 to T+4 hours

Inject statement

The bank must decide whether to halt certain payment classes, reconstruct the affected transaction population, and escalate immediately to compliance leadership and regulators.

What participants know at this stage

- Preliminary investigation indicates screening integrity may have been compromised.
- Some transactions may have proceeded without proper sanctions or AML checks.
- The duration of exposure is not yet confirmed.
- A regulator inquiry or supervisory contact is expected or has already begun informally.
- Executive leadership asks whether payments should continue and when the issue will be contained.

Facilitator prompts

- What are the criteria for halting all payments versus only selected payment classes or corridors?
- Who has decision authority for pausing transactions and invoking compensating controls?
- How will the bank identify the affected population and prove completeness of the lookback?
- What should be reported immediately to compliance leadership, legal, and regulators?
- What messaging should be used for senior management, operations staff, and customer-facing teams?
- What evidence is needed before normal processing can resume?

Expected actions

- Establish the initial start and end window of possible control failure.
- Segment affected transaction populations by risk.
- Apply holds, queues, increased manual review, or temporary pauses for higher-risk activity.
- Launch retrospective screening / replay planning.
- Escalate to compliance leadership, legal counsel, crisis management, and executive stakeholders.
- Prepare a regulator-ready fact pattern, including known facts, unknowns, immediate actions, and next update timing.

Facilitator notes

- Push for realistic trade-offs between regulatory risk and business disruption.
- Test whether participants can articulate compensating controls that are credible under supervisory scrutiny.

Optional Inject 3 — Root cause uncertainty deepens

Time: T+1 business day

Inject statement

Technical review confirms that screening rules and/or reference data were altered in a way that caused fail-open behavior. It remains unclear whether the cause was unauthorized tampering, privileged misuse, or defective deployment.

What participants know at this stage

- Integrity of rule sets or watchlists cannot yet be trusted.

- Some administrative activity occurred before alert volumes collapsed.
- Manual screening capacity is limited and backlogs are growing.
- Several high-value transactions require urgent business decisioning.

Facilitator prompts

- How do you balance containment, forensic preservation, and the need to restore service?
- What evidence would support escalation to a more severe crisis-management posture?
- How are backlog and customer impact decisions documented and approved?

Expected actions

- Tighten change control and privileged access restrictions.
 - Increase monitoring for further integrity anomalies.
 - Prioritize urgent transactions using documented risk criteria.
 - Coordinate technical investigation with compliance validation.
-

Optional Inject 4 — Recovery and post-incident obligations

Time: T+2 business days

Inject statement

The organization has contained the issue and rebuilt confidence in screening rules and data sources. Leadership now requires a decision on resuming normal processing and completing post-incident reporting.

What participants know at this stage

- Restored controls have passed initial validation.
- Retrospective screening has identified a subset of transactions requiring escalated review.
- Regulators expect timely updates, root cause information, and remediation commitments.

Facilitator prompts

- What evidence is required before declaring recovery?
- What should the post-incident report include?
- What longer-term control improvements are mandatory?

Expected actions

- Obtain formal approval to resume standard processing.
 - Complete lookback, exception review, and remediation tracking.
 - Prepare regulator and executive post-mortem reporting.
 - Launch control enhancement initiatives.
-

11. Decision Points

Throughout the exercise, participants should address the following decision points:

1. Is this an operational anomaly, a cyber integrity incident, a compliance breach, or all three?
 2. Should transactions continue, queue, or stop entirely?
 3. What compensating controls are acceptable while root cause is under investigation?
 4. What is the lookback window and how will impacted transactions be identified?
 5. When should legal and compliance leadership formally notify regulators?
 6. What criteria define safe recovery?
 7. How should the organization document decisions for auditability and regulatory review?
-

12. Discussion Questions by Audience

Executive / crisis management

- What is the bank's current risk posture and what is the worst credible outcome?
- What decisions require executive approval right now?
- What level of transparency is required with regulators and the board?
- How much operational disruption is acceptable to protect compliance integrity?

Compliance / legal

- Does this meet internal thresholds for regulatory notification?
- What records must be preserved to support defensibility?
- How will the bank demonstrate completeness of retrospective review?
- What customer, correspondent, or supervisory disclosures may become necessary?

Operations / business

- Which payments or customer activities are highest priority?
- What manual workarounds are possible and where do they create risk?
- How will transaction backlogs, customer commitments, and service degradation be managed?

Technical / cyber

- What evidence supports rule tampering, data corruption, privileged misuse, or deployment failure?
 - What monitoring gaps prevented earlier detection?
 - How is integrity of rules, watchlists, and screening outcomes independently verified?
 - What recovery steps are needed before reconnecting or resuming full automation?
-

13. Expected Technical and Business Impacts

Technical impacts

- Loss of trust in screening outputs
- Possible tampering with rules, watchlists, or reference data
- Need for forensic preservation and integrity validation
- Increased logging, validation, and replay activity
- Potential backlog in dependent applications

Business and compliance impacts

- Possible processing of unscreened transactions
 - Regulatory reporting and supervisory scrutiny
 - Manual review burden and payment delays
 - Reputational exposure with customers and counterparties
 - Audit and control assurance implications
-

14. Facilitator Guide

Desired behaviors to observe

- Early recognition that a zero-alert condition can signal silent control failure
- Clear ownership between compliance, cyber, IT, and business operations
- Risk-based decision making for transaction holds and manual review
- Accurate escalation and decision logging
- Practical recovery criteria rather than optimistic assumptions

Common gaps to test for

- Overreliance on system availability metrics
- Unclear authority to pause payments
- Inability to define compensating controls
- Weak regulator communication planning
- No tested lookback / replay procedure for compliance screening failures

Stretch questions

- What if the issue affected only one geography or payment rail?
 - What if the incident began several days earlier than first assumed?
 - What if a regulator asks for proof that no prohibited transaction was processed?
 - What if manual screening volume exceeds staffing capacity?
-

15. Debrief and Lessons Learned

At the end of the exercise, capture observations under the following headings:

- Detection and validation
- Severity assessment and escalation
- Decision authority and governance
- Compensating controls
- Retrospective screening readiness
- Regulatory communications
- Recovery criteria and assurance
- Monitoring and long-term remediation

Suggested after-action outputs

- Action register with owners and due dates
- Control improvement plan for integrity monitoring and fail-open prevention
- Review of privileged access and change management over compliance systems
- Validation of regulator notification playbooks
- Test plan for retrospective screening / replay procedures

16. Suggested Improvement Actions

Based on the scenario, likely improvement themes include:

- Continuous integrity monitoring for screening rules and watchlists
- Independent validation of screening outputs versus expected baselines
- Stronger change control and privileged access review for compliance platforms
- Automatic detection of abnormal alert volume collapse
- Predefined fail-safe behavior for screening dependencies
- Tested procedures for transaction hold, replay, lookback, and regulatory escalation

17. MITRE ATT&CK Mapping

This scenario centers on integrity compromise of a compliance control rather than a traditional ransomware or phishing storyline. The following ATT&CK techniques are relevant as plausible scenario representations for how such an event could occur or be sustained:

ATT&CK Tactic	Technique	Relevance to Scenario
Initial Access / Persistence / Privilege Escalation	Valid Accounts (T1078)	A privileged or legitimate account could be used to alter rules, data, or system settings without immediately triggering availability alarms.

ATT&CK Tactic	Technique	Relevance to Scenario
Defense Evasion	Impair Defenses (T1562)	Adversary actions may degrade or bypass security and compliance monitoring by forcing screening to fail open or suppress expected detections.
Impact	Data Manipulation (T1565)	The central scenario element is alteration of screening logic, watchlists, or reference data that changes control outcomes.
Impact	Stored Data Manipulation (T1565.001)	Screening rules, watchlists, or interdiction data stored in the platform may be modified to affect decisioning.
Impact	Service Stop (T1489) (conditional)	If response actions require suspending dependent services or processing flows, service interruption may occur as part of containment or adversary action.
Collection / Discovery	Account Discovery (T1087) (conditional)	An adversary preparing to tamper with the platform may identify privileged accounts or administrative roles.

Exercise note: The STIX bundle explicitly identifies the attack pattern as “Tamper with compliance screening data or rules to fail open,” which aligns most directly with ATT&CK’s **Data Manipulation (T1565)** and **Stored Data Manipulation (T1565.001)** concepts.

18. Source Mapping from the STIX Bundle

The exercise content above was derived from the uploaded STIX objects, including:

- Organization identity: Banking organization subject to AML and sanctions-screening obligations
- Infrastructure: AML and sanctions screening platform
- Attack pattern: Tamper with compliance screening data or rules to fail open
- Incident: Integrity failure in AML and sanctions screening
- Inject note 1: Screening alerts unexpectedly drop to zero
- Inject note 2: Retrospective review and regulator call
- Courses of action: Integrity monitoring and retrospective transaction screening / escalation procedure

19. Ready-to-Use Opening Script

Today’s exercise simulates a cyber-related integrity failure affecting the bank’s AML and sanctions screening platform. During a period of normal transaction activity, alert volumes unexpectedly collapse, raising concern that transactions may be proceeding without the expected sanctions and AML controls. Participants should respond using current roles, procedures, and escalation paths. The objective is to test

how the organization detects, contains, escalates, and recovers from a silent but high-impact control failure with potential regulatory consequences.